

Chapter / Module 2

Cryptography

Leykun Birhanu

AAU-CS

Security Techniques: Cryptography

Terminologies

- **Cryptography**: Schemes for encryption and decryption
- **Encryption**: The process by which plaintext is converted into ciphertext.
- **Decryption**: Recovering plaintext from the ciphertext
- **Secret key**: Used to set some or all of the various parameters used by the encryption algorithm. In a classical (symmetric key) cryptography, the same secret key is used for encryption and decryption
- **Cryptanalysis**: The study of “breaking the code”. **Cryptanalysts!**
- **Cryptology**: **Cryptography** and **cryptanalysis** together constitute the area of cryptology.

Cryptography

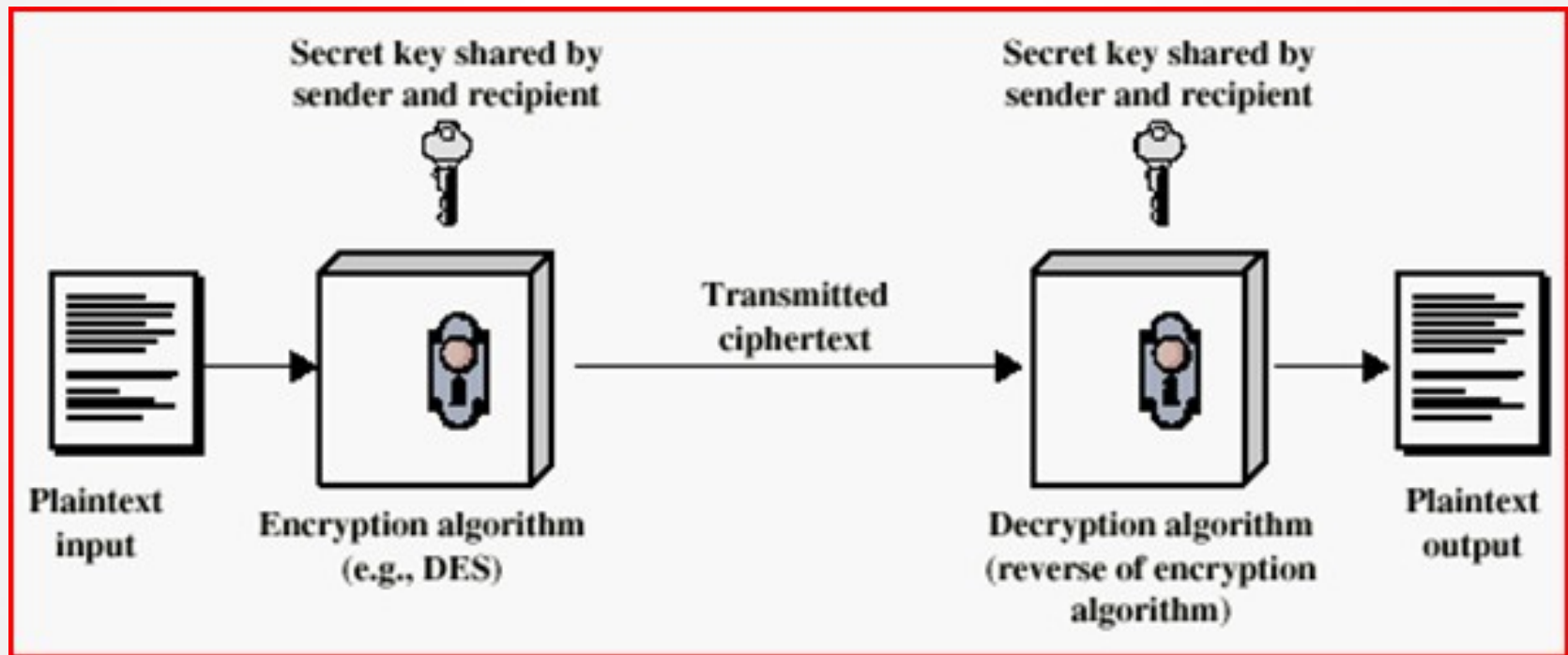
≡ **Cryptography** has five ingredients:

- Plaintext
- Encryption algorithm
- Secret Key
- Ciphertext
- Decryption algorithm

≡ Security depends on the secrecy of the **key**, not the secrecy of the **algorithm**

Cryptography

Simplified Encryption Model:



Cryptography

Description:

- ≡ A sender **S** wanting to transmit message **M** to a receiver **R**
- ≡ To protect the message **M**, the sender first encrypts it into an unintelligible message **M'**
- ≡ After receipt of **M'**, **R** decrypts the message to obtain **M**
- ≡ **M** is called the **plaintext**
 - What we want to encrypt
- ≡ **M'** is called the **ciphertext**
 - The encrypted output

Cryptography

Notation:

□ Given

● P = Plaintext

● C = CipherText

$$\square C = E_K(P)$$

Encryption

$$\square P = D_K(C)$$

Decryption

$$\rightarrow P = D_K(E_K(P))$$

$$\rightarrow C = E_K(D_K(C))$$

Cryptography

Caesar Cipher - early example:

☰ Caesar Cipher: The earliest known **example** of a substitution cipher in which each character of a message is replaced by a character three position down in the alphabet.

- Plain text: **are you ready**

- Cipher text: **duh brx uhdgb**

Cryptography

☰ If we represent each letter of the alphabet by an integer that corresponds to its position in the alphabet:

● The formula for replacing each character 'p' of the plaintext with a character 'c' of the ciphertext can be expressed as:

$$● c = E_3(p) = (p + 3) \bmod 26$$

Cryptography

☰ A more general version of this cipher that allows for any degree of shift:

● $c = E_k(p) = (p + k) \bmod 26$

☰ The formula for decryption would be

● $p = D_k(c) = (c - k) \bmod 26$

☰ In these formulas

● 'k' is the secret key. The symbols 'E' and 'D' stand for Encryption and Decryption respectively, and p and c are characters in the plain and cipher text respectively.

Cryptography

≡ Properties of encryption function

- It is computationally infeasible to find the key K when given the plaintext P and associated ciphertext $C = E_K(p)$
- It should also be computationally infeasible to find another key k' such as $E_K(p) = E_{K'}(p)$. Uniqueness.

Cryptography

≡Types of attacks encryption

- The **attacker** has only the **ciphertext** and his/her goal is to find the corresponding **plaintext**
- The **attacker** has a **ciphertext** and the corresponding **plaintext** and his/her goal is to find the key

≡A good cryptosystem protects against all types of attacks

≡Attackers use both Mathematics and Statistics

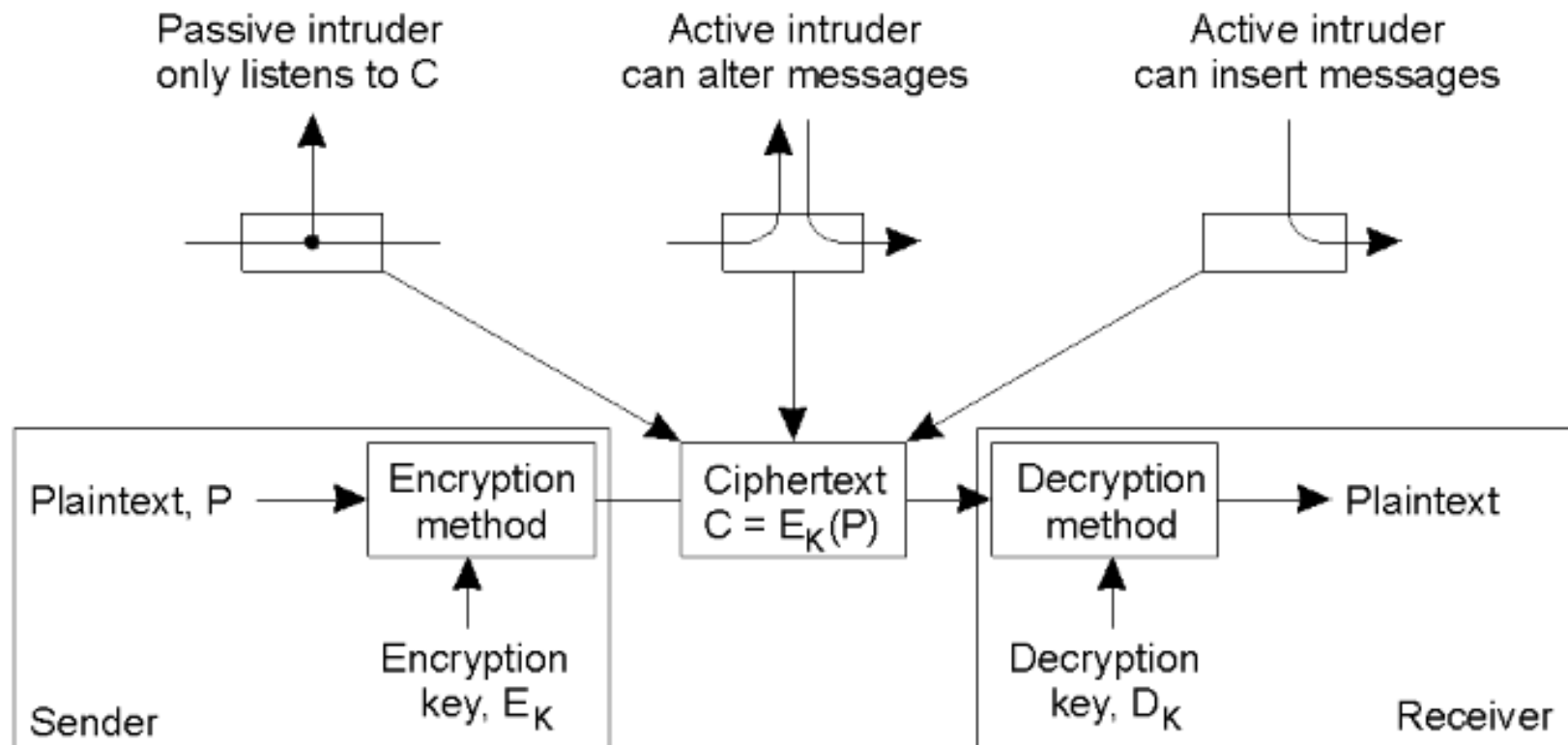
Cryptography

Intruders

- Eavesdropping (listening/spying the message)
 - An intruder may try to read the message
 - If it is well encrypted the intruder will not know the content
 - **However**, just the fact the intruder knows that there is communication may be a threat (Traffic analysis)
- Modification
 - Modifying a plaintext is easy, but modifying encrypted messages is more difficult
- Insertion of messages
 - Inserting new message into a ciphertext is difficult

Cryptography

Intruders



Cryptography

 There are two fundamentally different cryptographic systems

- Symmetric cryptosystem/ Private key encryption sys.
- Asymmetric cryptosystem/ Public key encryption sys.

Cryptography

Symmetric Cryptosystem

- Also called **secret-key/private-key** cryptosystem
- The same key is used to encrypt and decrypt a message
 - $P = D_K [E_K (P)]$
- Have been used for centuries in a variety of forms
- The key has to be kept secret
- The key has to be communicated using a secure channel
- They are still in use in combination with public key cryptosystems due to some of their advantages

Cryptography

Asymmetric Cryptosystem

☰ Also called **public-key** cryptosystem

- keys for encryption and decryption are **different** but form a unique pair

- $P = D_{KD} [E_{KE} (P)]$

- Only one of the keys need to be **private** while the other can be public

☰ Invented by **Diffie and Hellman** in 1976

☰ Uses Mathematical functions whose inverse is not known by Mathematicians of the day

☰ It is a revolutionary concept since it avoids the need of using a secure channel to communicate the key

☰ It has made cryptography available for the **general public** and made many of today's on-line application feasible

Cryptography

Public-key Cryptosystem

- ☰ Which one of the encryption or decryption key is made public depends on the use of the key
 - If **Hana** wants to send a confidential message to **Ahmed**
 - She encrypts the message using Ahmed's public key
 - Send the message
 - Ahmed will then decode it using his own private key
 - On the other hand, if Ahmed needs to make sure that a message sent by Hana really comes from her, **how can he make that?**

Cryptography

Public-key Cryptosystem

Digital signature

- Hana has to first encrypt a digital signature using her private key
- Then encrypt the message (signature included) with Ahmed's public key
- Sends the encrypted message to Ahmed
- Ahmed decrypts the message using his private key
- Ahmed then decrypts the signature using Hana's public key
- If successful, he insures that it comes from Hana

Cryptography

Hash functions

- ☞ One application of cryptography in distributed systems is the use of hash functions
- ☞ A hash function H takes a message m of arbitrary length and produces a bit string h , $h = H(m)$
- ☞ When the hash value h is sent with the message m , it enables to determine whether m has been modified or not
- ☞ It is similar to cyclic-redundancy check (CRC) and Check sum

Cryptography

Hash functions

☰ Properties of hash functions

- One-way function: It is computationally infeasible to find **m** that corresponds to a known output of **h**
- Collision resistance
 - Weak-collision resistance: It is computationally infeasible, given **m** and **H**, to find $m' \neq m$ such that $H(m) = H(m')$
 - Strong-collision resistance: **Given H**, it is computationally infeasible to find any **two different input values m and m'**, such that $H(m) = H(m')$

Cryptography

Average time required for exhaustive key search

Key Size (bits)	Number of Alternative Keys	Time required at 10^6 Decryption/ μ s
32	$2^{32} = 4.3 \times 10^9$	2.15 milliseconds
56	$2^{56} = 7.2 \times 10^{16}$	10 hours
128	$2^{128} = 3.4 \times 10^{38}$	5.4×10^{18} years
168	$2^{168} = 3.7 \times 10^{50}$	5.9×10^{30} years

Cryptography

DES - Popular Example of Symmetric Cryptosystem

■ In 1973, the NBS (National Bureau of Standards, now called NIST - National Institute of Standards and Technology) published a request for an encryption algorithm that would meet the following criteria:

- have a high security level
- be easily understood
- **not depend on the algorithm's confidentiality**
- be adaptable and economical
- be efficient and exportable

■ In late 1974, IBM proposed "**Lucifer**", which was then modified by NSA (National Security Agency) in 1976 to become the **DES (Data Encryption Standard)**.

■ DES was then approved by the NBS in 1978. DES was standardized by the ANSI under the name of ANSI X3.92, also known as **DEA (Data Encryption Algorithm)**.

Cryptography

DES- Example of Symmetric Cryptosystem ...

- DES Utilizes block cipher, which means that during the encryption process, the plaintext is broken into fixed length blocks of 64 bits.

- The key is 56 bits wide. 8-bit out of the total 64-bit block key is used for parity check (for example, if odd parity is used, each byte has an odd number of bits set to 1).

- 56-bit key gives 2^{56} ($\cong 7.2 \cdot 10^{16}$) possible key variations

- DES algorithm involves carrying out combinations, substitutions and permutations between the text to be encrypted and the key, while making sure the operations can be performed in both directions (for decryption).

- The combination of substitutions and permutations is called a product cipher.

Cryptography

DES- Example of Symmetric Cryptosystem ...

- DES was best suited for **implementation in hardware**, probably to discourage implementations in software, which tend to be slow by comparison during that time.
- Modern computers are so fast that satisfactory **software implementations** for DES are possible.
- DES is the **most widely used symmetric algorithm** despite claims whether 56 bits is long enough to guarantee security.
- Using current technology, 56-bit key size is vulnerable to a **brute force attack**.

Cryptography

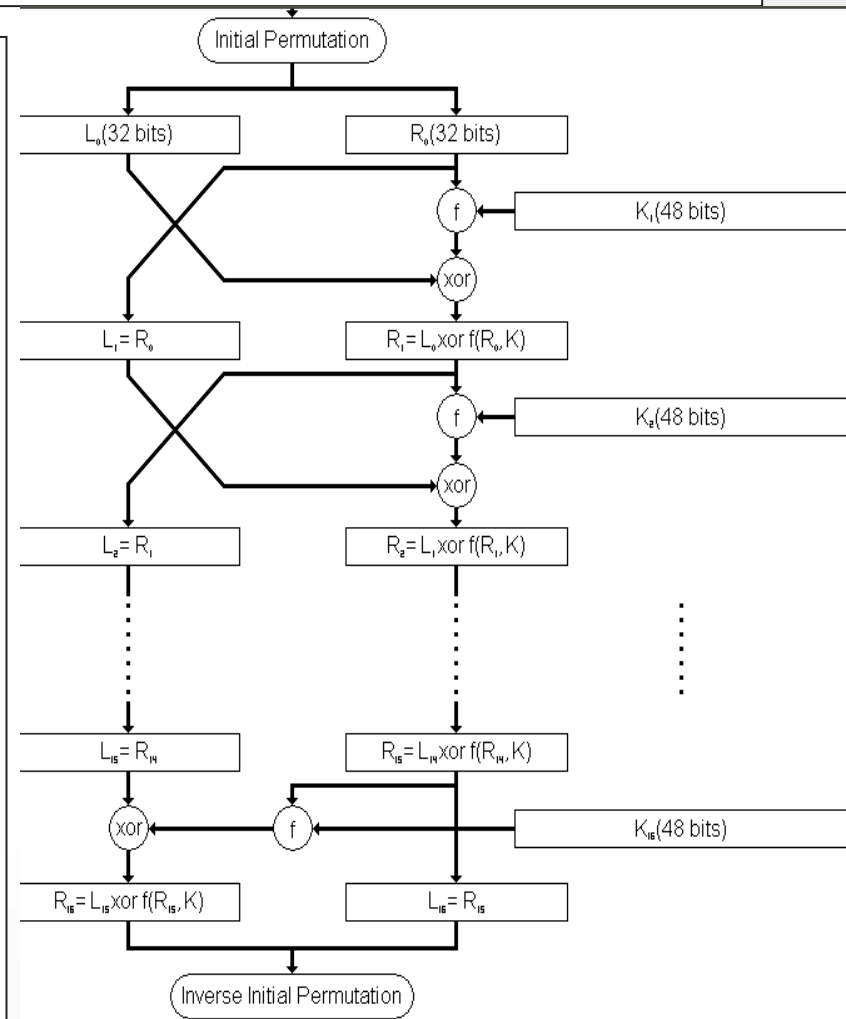
DES- Example of Symmetric Cryptosystem ...

DES Encryption starts with an initial permutation (IP) of the 64 input bits. These bits are then divided into two 32-bit halves called **L** and **R**. The encryption then proceeds through 16 rounds, each using the **L** and **R** parts, and a subkey.

The **R** and subkeys are processed in the so called *f*-function, and exclusive-or of the output of the *f*-function with the existing **L** part to create the new **R** part. The new **L** part is simply a copy of the incoming **R** part.

In the final round, the **L** and **R** parts are swapped once more before the final permutation (FP) producing the 64 bits output block.

Decryption is identical to encryption, except that the subkeys are used in the opposite order. That is, subkey 16 is used in round 1, subkey 15 is used in round 2, etc., ending with subkey 1 being used in round 16.



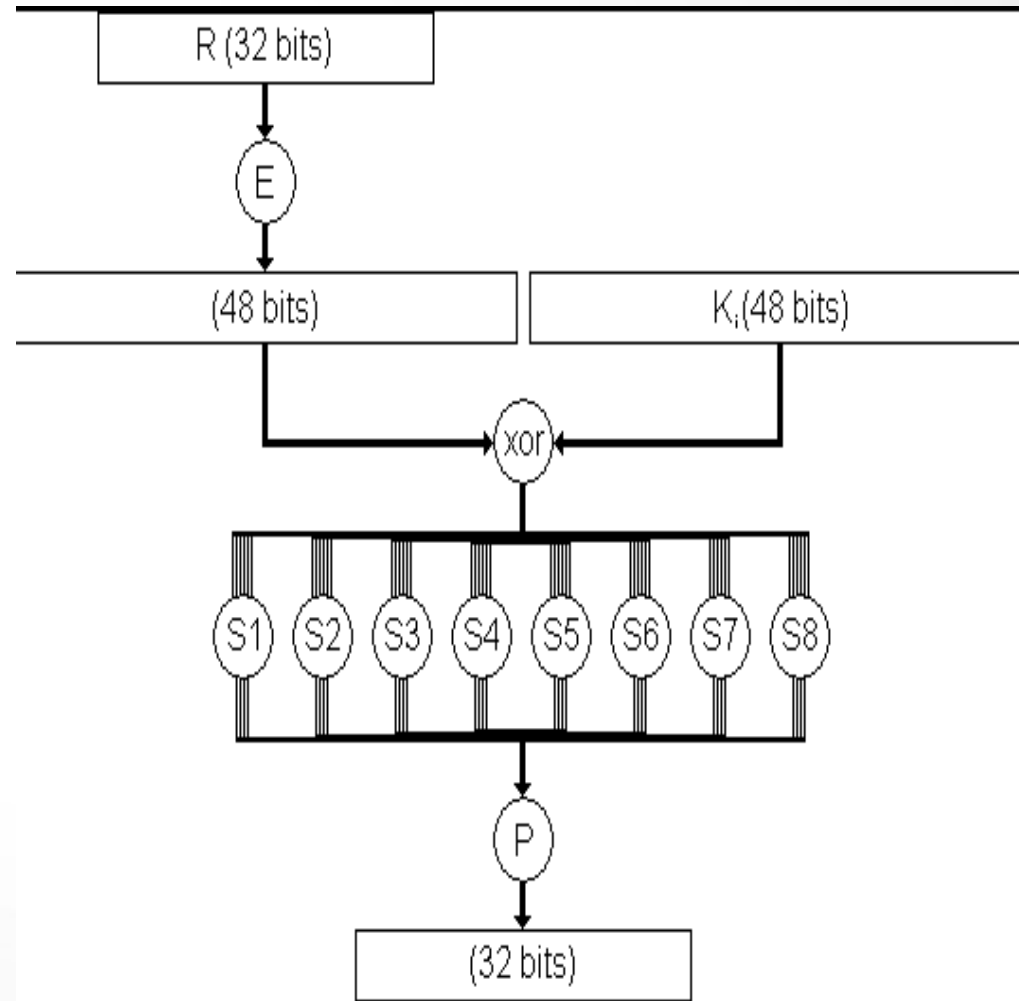
Cryptography

DES- Example of Symmetric Cryptosystem ...

■ The f -function mixes the bits of the R portion using the Subkey for the current round. First the 32-bit R value is expanded to 48-bits using a permutation E. That value is then exclusive-or'ed with the subkey.

■ The 48-bits are then divided into **eight** 6-bit chunks, each of which is fed into an S-Box that mixes the bits and produces a 4-bit output. A little bit funny operation here!!

■ Those **eight** 4-bit outputs are combined into a 32-bit value, and permuted once again to give the output of the f -function.



DES- Algorithm, the f -function

Cryptography

DES - Attacks

- **Cracking:** The most basic method of attack for any cypher is brute force - trying every possible key in turn.
- The length of the key determines the number of possible keys, and hence the feasibility of the approach.
- DES is not adequate with this regard due to its key size
- In academia, various proposals for a **DES-cracking machine** were advanced.
 - In 1977, Diffie and Hellman proposed a machine costing an estimated US\$20 million which could find a DES key in a single day.
 - By 1993, Wiener had proposed a key-search machine costing US\$1 million which would find a key within 7 hours.
- However, **none** of these early proposals were ever **implemented**.

Cryptography

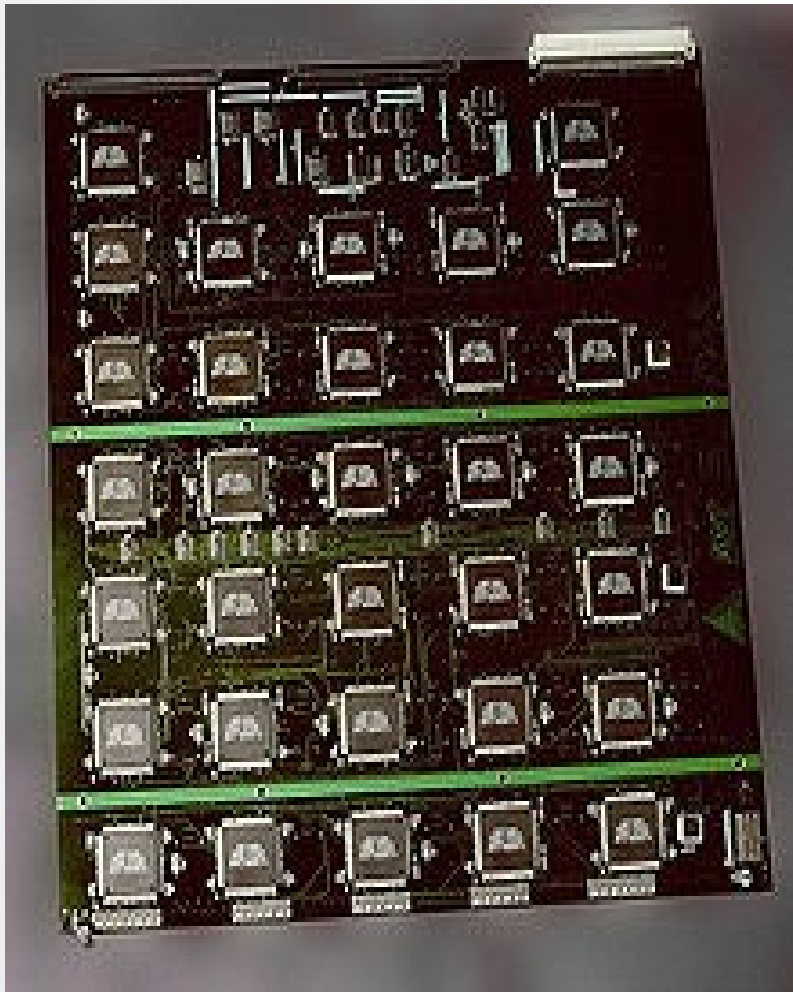
DES – Attacks ...

■ The **vulnerability** of DES was practically demonstrated in 1997, where RSA Security sponsored a series of contests, offering a \$10,000 prize to the first team that broke a message encrypted with DES for the contest. That contest was won by the DESHALL Project, led by Rocke Verser, Matt Curtin, and Justin Dolske, using idle cycles of thousands of computers across the Internet.

■ The feasibility of cracking DES quickly was demonstrated in 1998 when a custom DES-cracker was built by the Electronic Frontier Foundation (EFF), a cyberspace civil rights group, at the cost of approximately US\$250,000. Their motivation was to show that DES was breakable in practice as well as in theory.

Cryptography

DES- – Attacks ...



The EFF's US\$250,000 DES cracking machine contained 1,856 custom chips and could brute force a DES key in a matter of days - the photo shows a DES Cracker circuit board fitted with several Deep Crack chips.

Cryptography

DES - Variants

■ A variant of DES, **Triple DES** (3-DES), provides enhanced security by executing the core algorithm three times in a row.

■ With triple length key of three 56-bit keys K1, K2 & K3, encryption is:

- Encrypt with K1
- Decrypt with K2
- Encrypt with K3

■ Decryption is the reverse process:

- Decrypt with K3
- Encrypt with K2
- Decrypt with K1

■ Setting K3 equal to K1 in these processes gives us a double length key K1, K2.

■ Setting K1, K2 and K3 all equal to K has the same effect as using a single-length (56-bit key).

■ Thus it is possible for a system using triple-DES to be compatible with a system using single-DES.

Group Presentation Topic

Present how DES works.

Cryptography

Public-key Cryptosystem

≡ Properties of public key cryptosystem

- A pair of keys (private, public)
- If you have the private key, you can easily decrypt what is encrypted by the public key
- Otherwise, it is computationally infeasible to decrypt what has been encrypted by the public key

Cryptography

Public-key Cryptosystem: Example RSA

- **RSA** is from R. **R**ivest, A. **S**hamir and L. **A**ldermen

- **Principle:** No mathematical method is yet known to efficiently find the prime factors of large numbers

- **In RSA**, the private and public keys are constructed from very large prime numbers (consisting of hundred of decimal digits)

- One of the keys can be made public

- **Breaking RSA** is equivalent to finding the **prime factors**: this is known to be computationally infeasible

- It is only the person who has produced the keys from the prime numbers who can easily decrypt the messages

Cryptography

More on RSA

The RSA algorithm

- Used for both public key encryption and digital signatures.
- Security is based on the difficulty of factoring large integers.

Major Activities

- Key Generation (Algorithm)
- Encryption
- Digital signing
- Decryption
- Signature verification

Cryptography

RSA- Key Generating Algorithm

1. Generate two large random primes, p and q
2. Compute $n = pq$ and $\phi = (p-1)(q-1)$
3. Choose an integer e , $1 < e < \phi$, such that $\gcd(e, \phi) = 1$
4. Compute the secret exponent d , $1 < d < \phi$, such that
5. ϕ divides $(ed-1)$
6. The **public** key is (n, e) and the **private** key is (n, d) .
 - Keep all the values d , p , q and ϕ secret
 - n is known as the *modulus*
 - e is known as the *public exponent* or *encryption exponent*
 - d is known as the *secret exponent* or *decryption exponent*.

Cryptography

RSA- Encryption

☰ Sender A does the following

- Obtains the recipient B's public key (n, e)
- Represents the plaintext message as a positive integer m
- Computes the ciphertext $c = m^e \bmod n$
- Sends the ciphertext c to B

RSA- Decryption

☰ Recipient B does the following

- Uses his private key (n, d) to compute $m = c^d \bmod n$
- Extracts the plaintext from the message representative m

Cryptography

RSA- Digital signing

☰ Sender A does the following

- Creates a *message digest* of the information to be sent
- Represents this digest as an integer m between 0 and $n-1$
- Uses *private* key (n, d) to compute the signature
 - $s = m^d \bmod n$.
- Sends this signature s to the recipient B.

RSA- Signature verification

☰ Recipient B does the following

- Uses sender A's public key (n, e) to compute integer $v = s^e \bmod n$
- Extracts the message digest from this integer
- Independently computes the message digest of the information that has been signed
- If both message digests are identical, the signature is valid

Cryptography

RSA- Key Generation Simple Example

1. Select primes $p=11$, $q=3$.
2. $n = pq = 11*3 = 33$
3. $\phi = (p-1)(q-1) = 10*2 = 20$
4. Choose $e=3$
5. Check $\gcd(e, p-1) = \gcd(3, 10) = 1$ (i.e. 3 and 10 are relatively prime - have no common factors except 1) and check $\gcd(e, q-1) = \gcd(3, 2) = 1$, therefore $\gcd(e, \phi) = \gcd(e, (p-1)(q-1)) = \gcd(3, 20) = 1$
6. Compute d ($1 < d < \phi$) such that ϕ divides $ed-1$ (20 divides $3d-1$.)
7. Simple testing ($d = 2, 3 \dots$) gives $d = 7$
8. Check: $ed-1 = 3*7 - 1 = 20$, which is divisible by ϕ (20).
9. Public key = $(n, e) = (33, 3)$
10. Private key = $(n, d) = (33, 7)$.

Cryptography

Given

Public key = $(n, e) = (33, 3)$

Private key = $(n, d) = (33, 7)$

RSA- Encryption Example

Now say we want to encrypt the message $m = 7$

- $c = m^e \bmod n = 7^3 \bmod 33 = 343 \bmod 33 = 13$

- Hence the ciphertext $c = 13$

RSA- Decryption Example

To check decryption we compute

- $m = c^d \bmod n = 13^7 \bmod 33 = 7$

Cryptography

RSA- More Meaningful Example

☰ Message: ATTACKxATxSEVEN

☰ Grouping the characters into **blocks** of three and computing a message representative integer for each block:

● ATT ACK XAT XSE VEN

● In the same way that a decimal number can be represented as the sum of powers of ten, e.g. $135 = 1 \times 10^2 + 3 \times 10^1 + 5$, we could represent our blocks of three characters in base 26 using A=0, B=1, C=2, ..., Z=25

● $ATT = 0 \times 26^2 + 19 \times 26^1 + 19 = 513$

● $ACK = 0 \times 26^2 + 2 \times 26^1 + 10 = 62$

● $XAT = 23 \times 26^2 + 0 \times 26^1 + 19 = 15567$

● $XSE = 23 \times 26^2 + 18 \times 26^1 + 4 = 16020$

☰ $VEN = 21 \times 26^2 + 4 \times 26^1 + 13 = 14313$

Cryptography

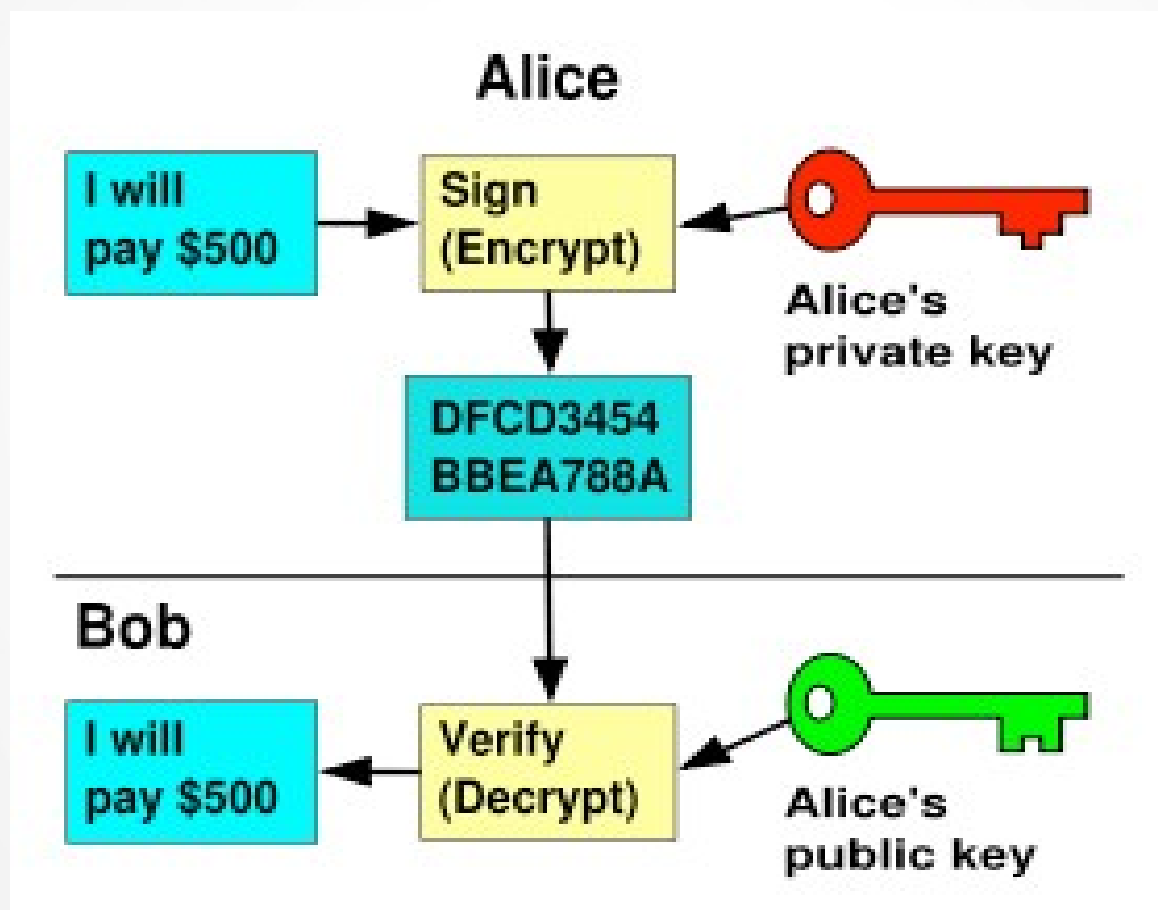
Do public and private key form a unique pair?

e and d form no unique pair!

- With RSA, we can make several private key for single public key and vice versa.
- We have to avoid to make more than one public key for a single private key because combining two such keys help revealing the private key.

Cryptography

Digital Signature



Cryptography

Digital Signature for Message Integrity and Confidentiality

- **Confidentiality** insures that messages cannot be intercepted and read by eavesdroppers
- **Message integrity** insures that messages are protected against modification

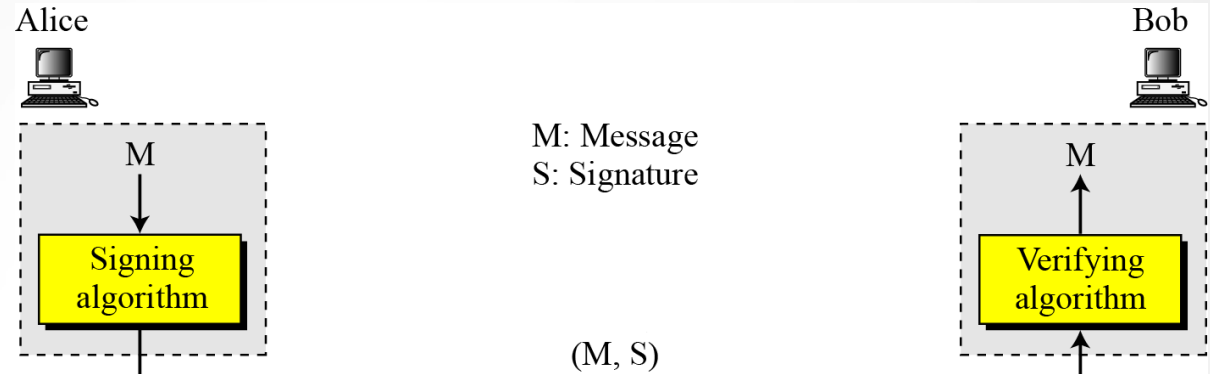
■ Principles of Digital Signature

- User **A** signs digitally a message **m** using “cryptographic hash of the message **m** with the **private key** of **A** and attach it to the message **m**.”
- Anybody can then decrypt **A’s** digital signature using **A’s** **public key** and compare it with the cryptographic hash of the message **m** to verify that **m** was **signed by A** and **m** was **not altered**.

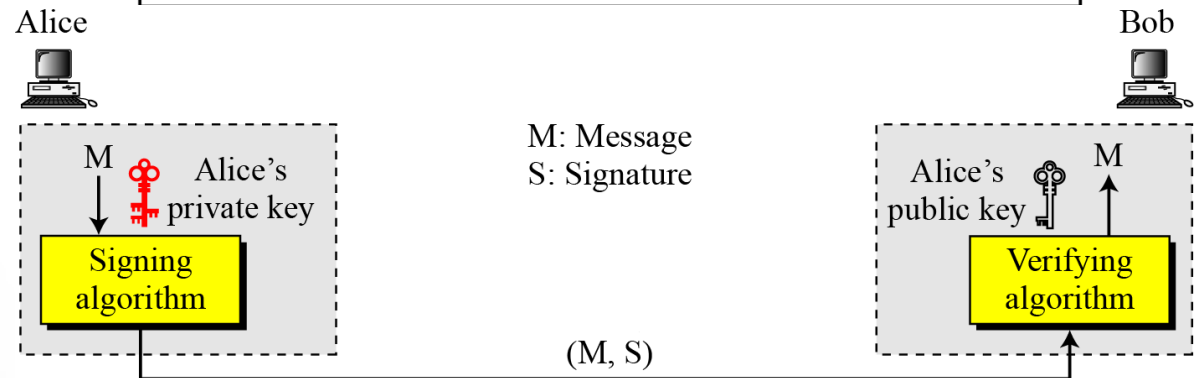
Cryptography

Digital Signature - Principles

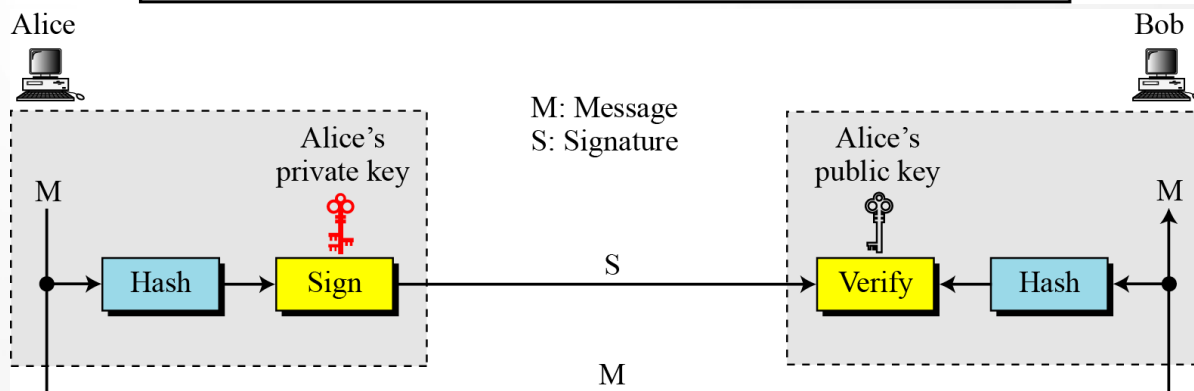
Process



With Key



With Message Digest



Cryptography

Digital Signature for Assurance

- Consider the situation where Bob has just sold Alice something for 500 Birr through a deal that is made by E-mail
- Alice sends an E-mail accepting to pay 500 Birr

- Two issues need to be taken care of in addition to authentication
 - Alice needs to be assured that Bob will not modify the amount and show that Alice promised to pay more than 500 Birr
 - Bob needs to be assured that Alice will not deny that she sends the message

- If Alice signs the message digitally, the two issues will be solved

- There are several ways to place digital signatures
- One popular way is to use public-key cryptosystem such as RSA

Cryptography

Digital Signature Using Public Key Cryptosystem

Notation: K_X^- : Private key of X
 K_X^+ : Public key of X

☰ When Alice sends her message m to Bob, she encrypts it with her private key $K_A^-(m)$

☰ If she wants to keep the message content a secret, she can use Bob's public key and send $K_B^+(m, K_A^-(m))$

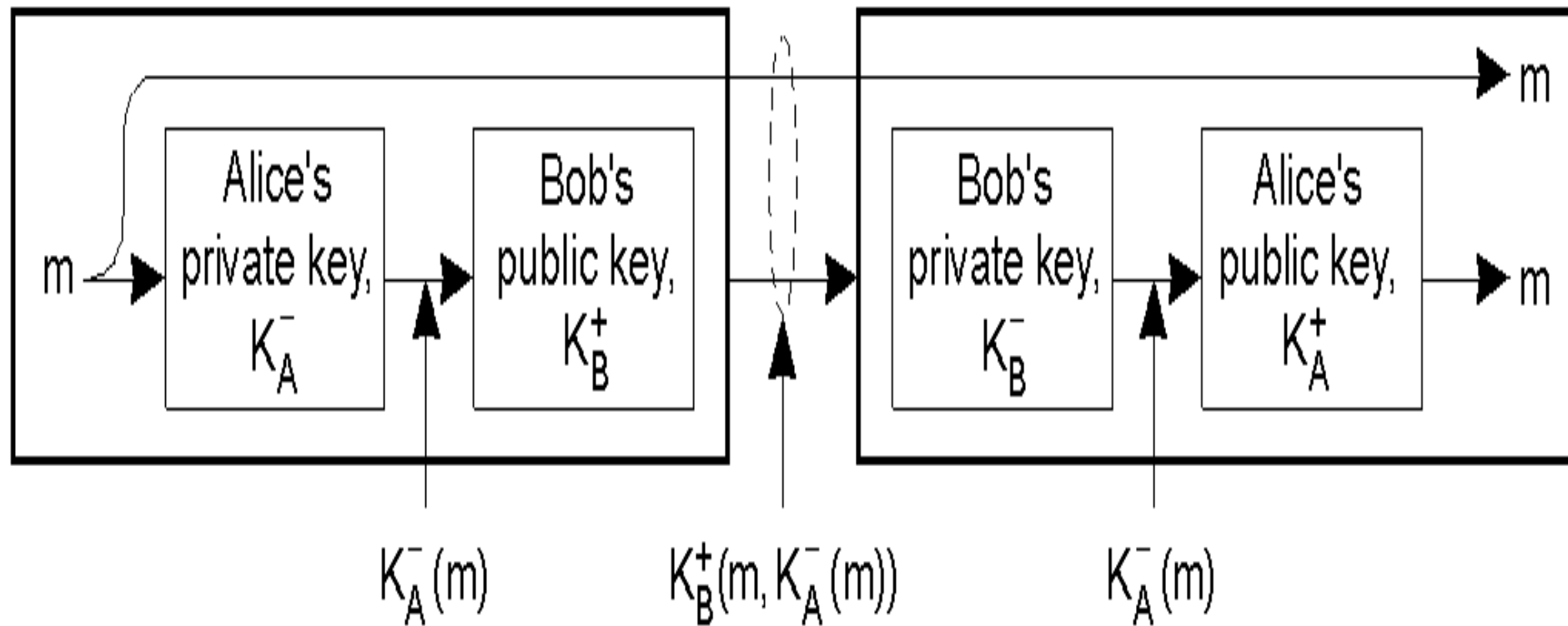
☰ Alice is protected against modification by Bob since if Bob produces m' , he has to find $K_A^-(m')$

Cryptography

Digital Signature Using Public Key Cryptosystem ...

Alice's computer

Bob's computer



Cryptography

Digital Signature Using Message Digest

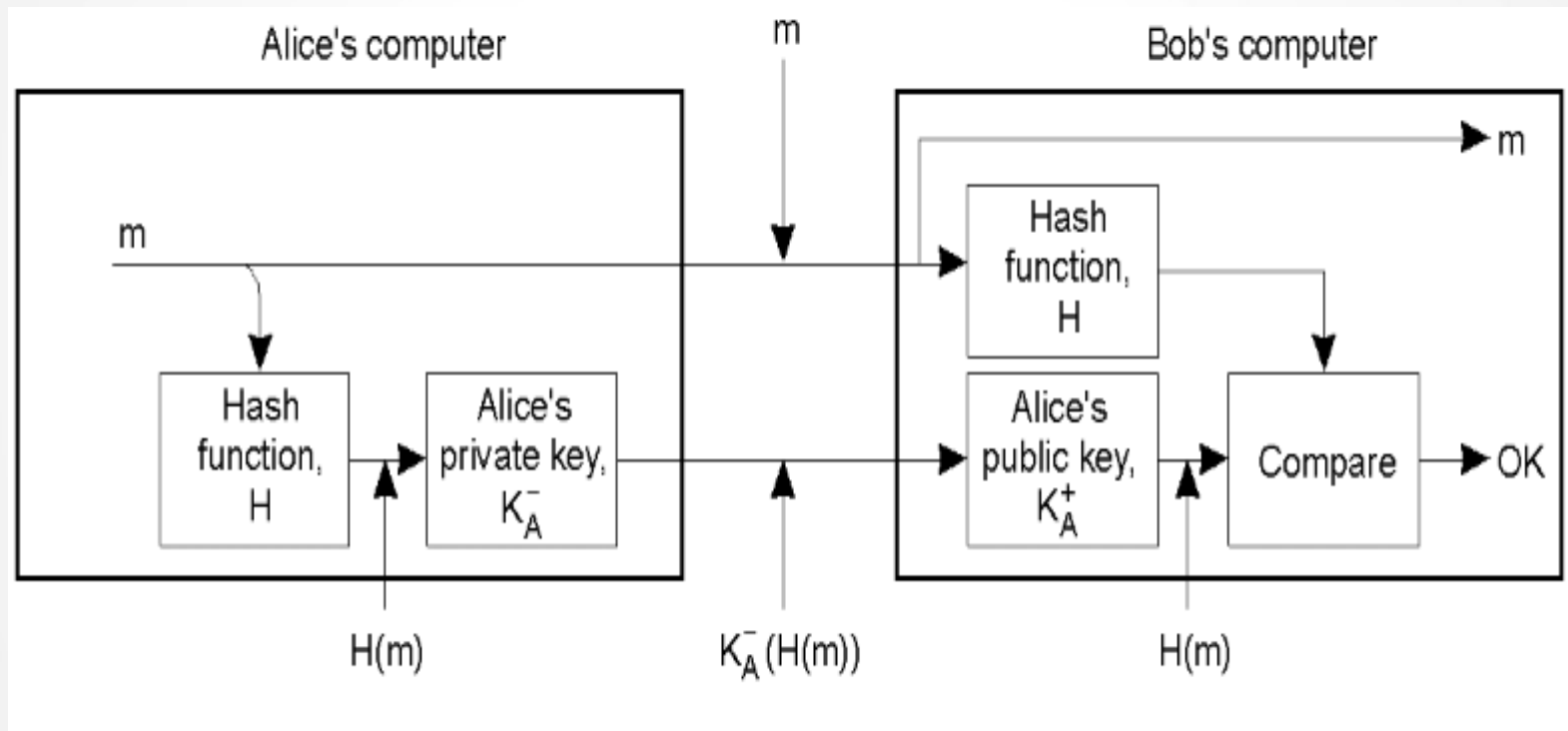
- **Hash/Message Digest:** Short “signature” of the message, 128–512 bits, that depend on entire message
- It is *extremely* improbable that unequal messages have same hash

Example: MD5 (Message Digest *version 5*)

- $H = H(m)$ is sent along m , where H is a cryptographic hash function
- $K_A^-(H(m))$ (or $K_B^+(m, K_A^-(H(m)))$) is sent so that Bob knows that it comes from Alice by decrypting it
- Bob hashes the message m and compares it with H that he has received from Alice

Cryptography

Digital Signature Using Message Digest ...



Cryptography

Key Distribution: Verifying Someone's Public Key

- Even with public-key cryptosystems and digital signatures, we still have the problem of authentication: **binding users to keys**.
- Early days articles envisioned phonebook-like **database** with Name and Public Key entries.

Problem: How secure is that database itself?

- Attacker can put in his own key for someone else, and start signing fake contracts (and even checks!).
- Maybe we can secure the phonebook, but then it **kills** the idea of keys widely and easily available (**publicly**) .

Cryptography

Key Distribution: Problems

- ☰ Distribution of a key is a difficult matter!

- ☰ For a **symmetric cryptosystem**, the initial key must be communicated along a **secured channel(?)**

- ☰ For **public key**, we need a body that certifies the public key is that of the party we need to communicate with

- ☰ **Solution:** Certification/**C**ertificate Authority (**CA**) that signs (certifies) the public key

Cryptography

Certification

- The critical thing is that the name in the certificate must **match** the alleged name.

- Common solution to public key distribution today is to have **trusted third party** to sign the user's public encryption key.

- A **certificate** is a public key and some naming “stuff”, digitally signed by someone you trust (third party) - Certification Authority (CA).

- **Remark:** Just because they are CAs doesn't mean you should trust them.

- Resulting certificate will contain information like user's name/ID, user's public key, name of CA, start date of certificate, and length of time it is valid.

- User publishes certificate with the **X.509** standard (for formatting certificates).

Cryptography

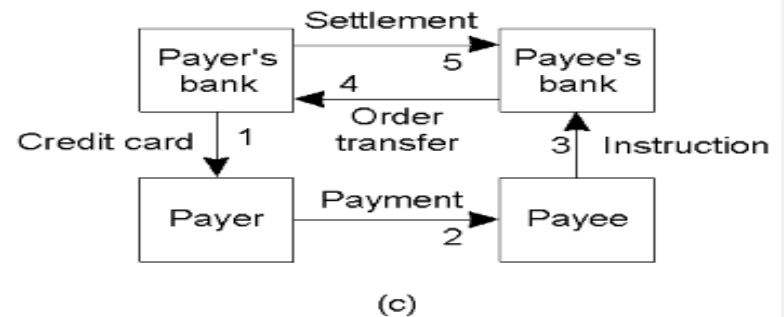
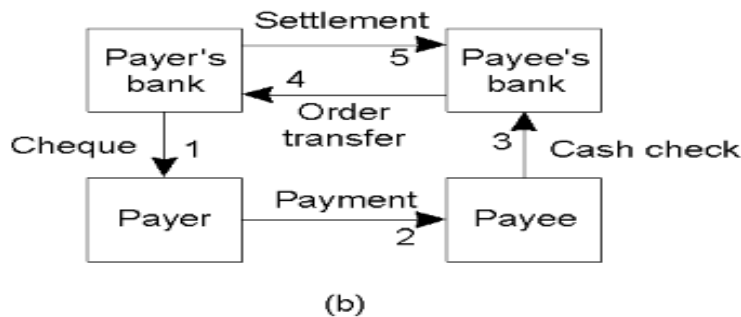
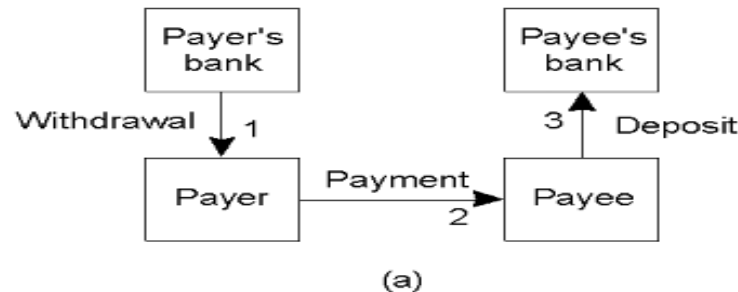
Certification - Associated Overheads

- An important issue is the longevity of certificates
- Lifelong certificates are not feasible

- Therefore, we need a way to revoke certificates
 - Certificate Revocation List (CRL) published regularly
 - Problems
 - Vulnerability between the publishing and the request for revocation
 - Restricting the lifetime of a certificate
 - A client contacts the certification authority for each public key, checks whether it is valid or not

Cryptography

Applications – Electronic Payment

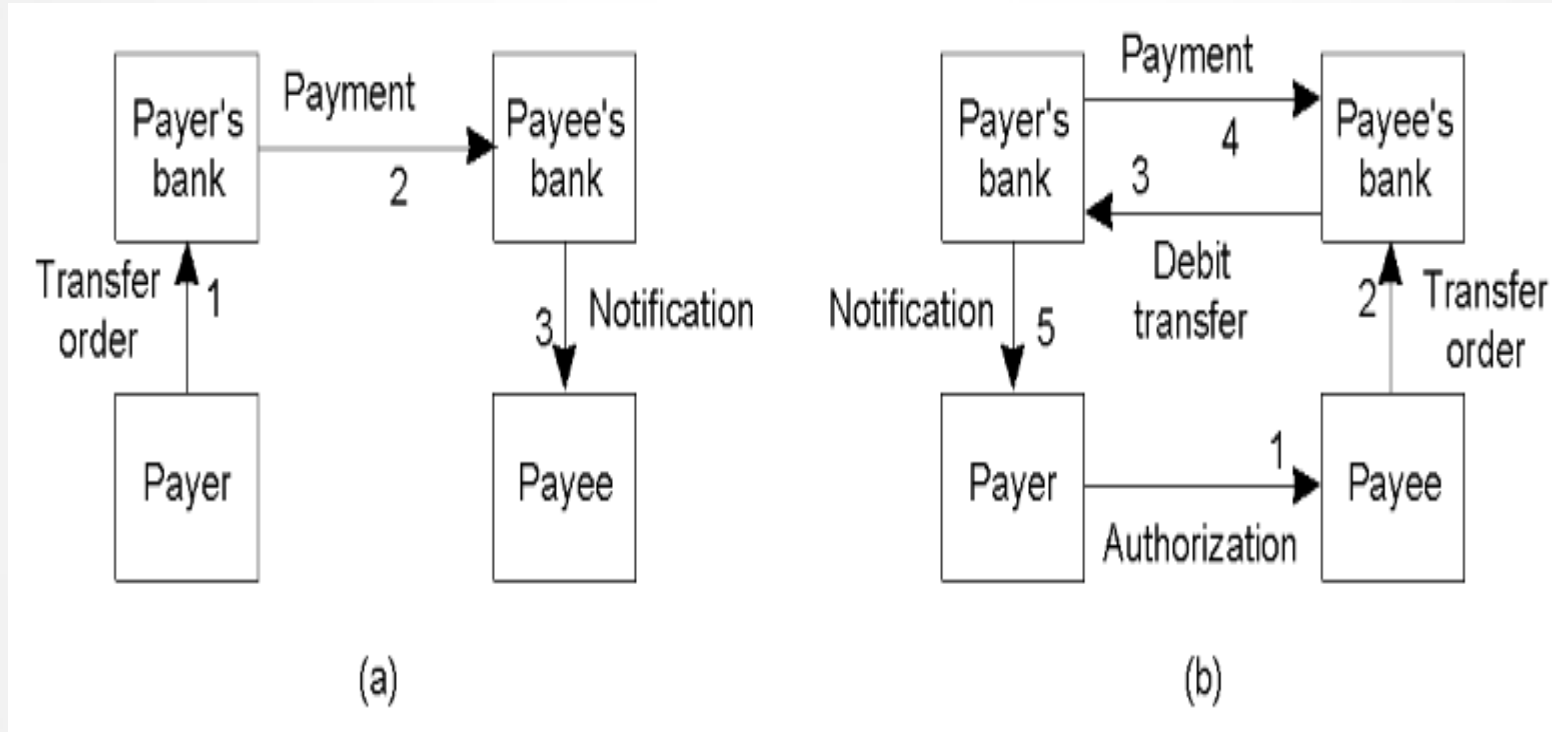


Payment systems - based on direct payment

- a) Paying in cash.
- b) Using a check.
- c) Using a credit card.

Cryptography

Applications – Electronic Payment ...



☰ Payment systems based on money transfer between banks.

a) Payment by money order.

b) Payment through debit order.

Cryptography

Applications – Security in Electronic Payment

General requirements

- In cash based systems (using ATM), the main issue is authentication
 - Use of magnetic card
 - PIN
- Digital money
 - Protection against fraud
 - It should not be possible to use the money more than once
 - It should not be possible to use forged money
- Credit card or check based system
 - No tampering/alteration
 - Protection against repudiation (the buyer denies having made the order)

Cryptography

Use of Session keys

During the establishment of a **secure channel**, after the authentication phase, the communicating parties use **session/temporary keys**

Benefits

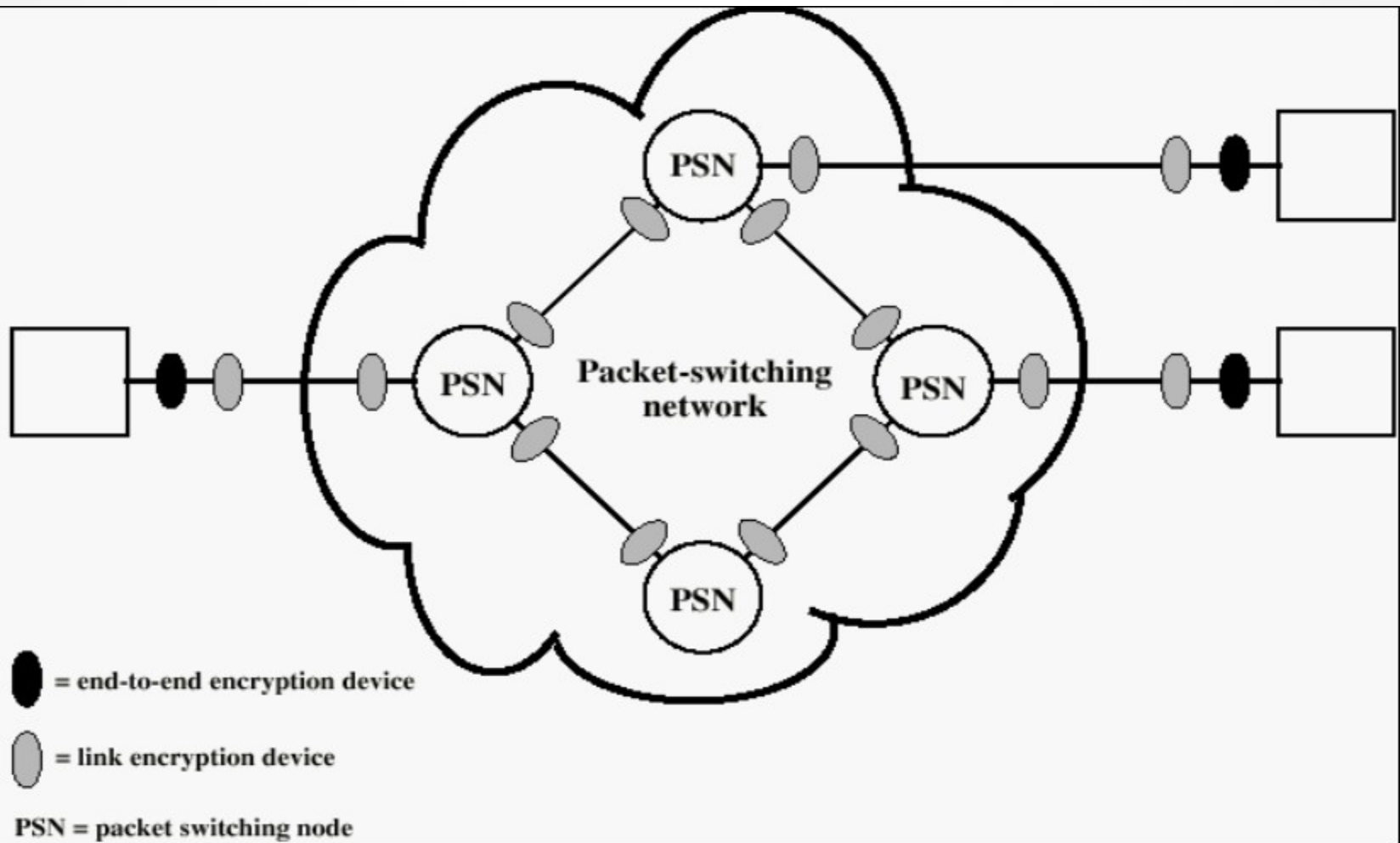
- The session key is safely discarded when the channel is no longer used
- When a key is used very often it becomes vulnerable. Thus by using the main key less often, we make them less vulnerable
- Replay attacks can be avoided

Authentication keys are often expensive to replace

Such a combination of long-lasting and cheaper/more temporary/session keys is a good choice

Cryptography

Summary: Location of Encryption/Decryption Devices



Cryptography

Summary

≡ Advantage of private-key (symmetric/secret-key) cryptography is that it provides better secrecy but needs prearranged key exchange.

≡ Advantage of public-key (asymmetric) cryptography is that it allows for secrecy between two parties who have not arranged in advance to have a shared key (or trusted some third party to give it to them) and the disadvantage is overhead and speed.

≡ Therefore, in practice, hybrid systems use public-key to establish session key for private key !!

Security Techniques: Cryptography

